

Modality Limits

1. What Is a Modality and Why Does It Matter for Security?

In AI systems, a modality is a type of input data format: text, image, audio, video, structured data, or combinations thereof. Multi-modal AI systems that accept several formats simultaneously are increasingly common—they are also increasingly complex to secure. The key security principle is that each modality is a distinct attack surface with its own vulnerabilities, validation requirements, and computational cost profile.

Modality limits apply the principle of least privilege at the data-type level: an AI system that only needs text inputs to fulfil its function should accept only text. Admitting images, audio, or video when these are unnecessary increases attack surface without increasing capability. The SecAI+ exam tests whether you can identify the modality risks in a given scenario and recommend the appropriate restrictive controls.

2. Modality Risk Matrix

Modality	Unique Attack Vectors	Processing Cost	Recommended Stance
Text	Prompt injection, jailbreaking, social engineering	Low	Accept if needed; validate length and encoding
Image	Adversarial pixels, steganography, embedded malware, oversized files	Medium	Accept only when genuinely required; strict format allow-list and malware scan
Audio	Subliminal ultrasonic commands, payload embedding, DoS via large files	High	Accept only when necessary; limit duration and file size; validate headers
Video	All image + audio risks; extreme resource consumption; frame-level attacks	Very High	Avoid unless essential; strict sandbox; aggressive size and duration limits
Document (PDF/DOCX)	Macro execution, embedded scripts, metadata leakage, embedded images	Medium	Strip active content; validate format; scan for macros
Structured data (JSON/CSV)	Schema injection, nested bomb payloads, encoding attacks	Low–Medium	Validate schema; enforce nesting depth limits

3. Adversarial Image Attacks: Beyond Steganography

Real-World Research — Adversarial Patch Attacks on Vision Models (Google Brain / Eykholt et al., 2017–2018): Researchers demonstrated that small, carefully crafted stickers applied to stop signs caused autonomous vehicle vision models to misclassify them as speed limit signs. Separately, adversarial

perturbations invisible to the human eye caused AI classifiers to confidently misidentify images. These attacks generalise to any vision-enabled AI, including security systems that analyse screenshots, scan documents, or process surveillance imagery.

For security AI, the implications are direct. An AI system that analyses screenshots for policy violations or insider threat indicators can be deceived by adversarial images. An AI that examines uploaded identity documents can be manipulated by subtly altered images that appear legitimate to humans but not to the model. Mitigations include: processing images in sandboxed environments, running images through adversarial detection pre-processing, and applying secondary validation for high-stakes decisions.

4. Steganography: Data Hidden in Plain Sight

Steganography is the practice of concealing data within an apparently innocuous carrier file. In the context of modality security, an attacker can embed malicious content—command-and-control instructions, stolen data, or exploit payloads—within an image, audio file, or video that passes superficial inspection. The challenge for AI systems is that the model may process the visible content normally while the hidden payload is extracted by a separate mechanism.

Defences against steganographic attacks in AI input pipelines include:

- Format conversion — convert images to a canonical format (e.g. decompress and re-compress as a fresh PNG) before processing. This destroys most steganographic payloads without affecting legitimate image content.
- Statistical analysis — tools such as steganalysis engines can detect statistical anomalies in image data that indicate steganographic embedding.
- Metadata stripping — remove EXIF and other metadata fields that are commonly used as steganographic carriers.
- Content-only extraction — for use cases where the text content of an image is what matters, use OCR to extract text and discard the image entirely.

5. MIME Type Spoofing and Magic Number Validation

File type declarations—the file extension and the MIME type in the HTTP header—are user-controlled and trivially falsified. An attacker can rename an executable as image.jpg and upload it to an AI system that accepts images. If the system trusts the declared type, it will attempt to process an executable as an image, with unpredictable results that may include arbitrary code execution in the image processing pipeline.

Magic Number Validation: Never trust file extensions or declared MIME types. Validate the actual file content using the file's first bytes (magic numbers/file signatures) to confirm the true format before processing.

Common magic number signatures: PNG files begin with bytes 89 50 4E 47; JPEG files begin with FF D8 FF; PDF files begin with 25 50 44 46. A file claiming to be a PNG but beginning with 4D 5A (the MZ header

of a Windows executable) must be rejected immediately. Magic number libraries (python-magic, libmagic) automate this check and should be integrated at the preprocessor layer.

6. Sandboxed Processing by Modality

Processing different modalities in shared infrastructure creates lateral movement risk: a compromise in the image processing component could affect the text processing pipeline if they share memory space or process isolation. Best practice provisions separate sandboxes per modality, each with resource limits appropriate to the modality's cost profile and risk level.

Modality	Sandbox RAM Limit	Sandbox CPU Time Limit	Network Access	Isolation Level
Text	512 MB	5 seconds	None	Process-level
Image	2 GB	30 seconds	None	Container-level
Audio	4 GB	120 seconds	None	Container-level
Video	8 GB	300 seconds	None	VM-level
Document	1 GB	60 seconds	None	Container-level

Network access is disabled in all modality sandboxes. A malicious payload that achieves code execution within the sandbox cannot phone home or exfiltrate data if outbound network access is blocked. The sandbox exit is the file path for the extracted, validated output—not the original input.

7. The Downgrade Strategy: Converting to Simpler Modalities

One of the most effective modality security techniques is converting rich-format inputs to simpler, safer representations before AI processing. If a user submits a screenshot (image) and the AI only needs the text content, run OCR to extract the text and discard the image. If an audio recording is submitted for analysis of spoken content, transcribe to text and process the transcript. This approach:

- Eliminates adversarial image/audio attack vectors by discarding the carrier medium.
- Reduces processing cost significantly—text inference is far cheaper than vision or audio inference.
- Simplifies the validation problem—text is easier to sanitise and validate than binary media files.
- Maintains functionality for the majority of use cases where the AI is extracting meaning, not analysing the raw media.

The downgrade strategy is not applicable when the modality itself is the subject of analysis—for example, deepfake detection inherently requires video processing, and malware embedded in image structure cannot be detected after OCR discards the image data. In these cases, full modality processing in an isolated sandbox is required.

8. File Format Allow-Lists: Narrowing the Surface

Within any accepted modality, the number of accepted file formats should be minimised. The allow-list approach (accept only listed formats; reject everything else) is dramatically safer than a deny-list approach (reject known-bad formats; accept everything else). Exotic or rarely used formats are

disproportionately likely to contain parser vulnerabilities and have received less security scrutiny than common formats.

Practical allow-lists by modality: images—PNG and JPEG only (reject TIFF, BMP, SVG, WebP unless there is a specific business need); audio—WAV and MP3 (reject FLAC, OGG, exotic codecs); video—MP4/H.264 (reject AVI, MOV, MKV, exotic codecs); documents—PDF with active content disabled (reject DOCX with macros, PPTX, HTML). The narrower the allow-list, the smaller the parser attack surface.

9. Modality-Specific Malware Scanning

Generic antivirus scanning is insufficient for media files. Each modality requires scanners appropriate to its format and threat model:

- Images — scan for embedded macros (rare but possible in some formats), steganographic payloads, and format-level exploits (e.g. malformed PNG headers that trigger parser buffer overflows).
- Audio/Video — scan for embedded executables, malicious metadata fields, and format-level exploits in codec parsers.
- Documents — scan for macros, embedded scripts (JavaScript in PDF), embedded executable objects, and hyperlinks to malicious URLs.
- Structured data — validate schema strictly; scan for deeply nested payloads (JSON bombs) that expand during parsing.

The scanning layer sits between the gateway (format and size check) and the preprocessor (modality-specific validation), forming a three-stage funnel that filters out increasing classes of malicious input at each stage.

10. Analogy: Modality Limits as Border Control

A useful analogy for modality limits is international border control. Each crossing point (modality) admits different categories of traveller (input type), with different inspection regimes. A pedestrian border crossing only admits people on foot—vehicles, cargo, and animals are not permitted regardless of stated intent. A cargo crossing admits vehicles but subjects them to X-ray scanning and customs inspection not applied to passengers. Some crossings are closed entirely to non-citizens.

Applying this to AI systems: a text-only interface is the pedestrian crossing—it admits one type of input with straightforward inspection. An image-accepting interface is the cargo crossing—it admits a richer format with more intensive validation. A multi-modal interface is an international airport—capable of handling diverse input types, but only with correspondingly more complex security infrastructure. The security cost of each additional modality must be explicitly justified by business need.

Key Terms Glossary

Term	Definition
Modality	A type or format of input data accepted by an AI system, such as text, image, audio, video, or structured data.
Modality limit	A control that restricts which input data types an AI system will accept, applying the principle of least privilege at the format level.

Adversarial image	An image containing subtle pixel-level perturbations that are imperceptible to humans but cause an AI vision model to misclassify the image.
Steganography	The practice of concealing data (such as malicious payloads) within an apparently innocuous carrier file such as an image or audio file.
Magic number validation	Verifying the true file type by inspecting the first bytes of the file content (file signature), rather than trusting the declared extension or MIME type.
MIME type spoofing	Falsifying the declared content type of a file (e.g. labelling an executable as image/jpeg) to bypass format-based access controls.
Sandboxed processing	Executing media processing in an isolated environment with restricted memory, CPU, and network access to contain the impact of a successful exploit.
Format allow-list	A control that accepts only explicitly listed file formats within a modality, rejecting all others including unknown or exotic formats.
Downgrade strategy	Converting a rich-format input (image, audio, video) to a simpler, safer representation (typically text) before AI processing, eliminating the complex modality's attack surface.
Steganalysis	The statistical and computational analysis of media files to detect the presence of steganographically hidden content.

Quick Revision Checklist

- Each modality is a distinct attack surface—accept only modalities required for the AI system's function.
- Text is the lowest-risk modality; video is the highest-risk due to attack surface complexity and processing cost.
- Adversarial images contain imperceptible pixel perturbations that deceive vision AI models without appearing manipulated to humans.
- Steganography hides malicious payloads within legitimate-appearing media files; mitigations include format conversion and steganalysis.
- Never trust declared file extensions or MIME types—validate true file type using magic number (file signature) inspection.
- Process each modality in an isolated sandbox with resource limits appropriate to its cost and risk profile.
- Format allow-lists (accept only listed formats) are safer than deny-lists (block known-bad formats).
- The downgrade strategy converts rich inputs to text where possible, eliminating complex modality attack vectors.
- Modality-specific malware scanning is required—generic antivirus is insufficient for specialised media formats.
- Multi-modal systems multiply attack surface; each additional modality requires a full security review before adoption.

- Disable network access in all modality processing sandboxes to prevent exfiltration in the event of exploit success.

10 Exam-Based MCQs — Modality Limits

Test yourself after reading. These questions are written in real exam style — scenario-heavy, with plausible distractors. Read every explanation, including for questions you answered correctly.

Q1. Scenario: A financial services firm's AI compliance assistant accepts five input modalities. A security review reveals 98% of queries use only text or PDF, with zero audio submissions in six months. A financial services firm deploys an AI-powered compliance assistant that allows employees to submit questions and upload supporting documents. The compliance team reports that the AI currently accepts text, PDF, DOCX, image, and audio inputs. A security review identifies that 98% of queries are text-only or PDF-based, and no audio queries have been submitted in six months. Which recommendation BEST reduces the system's attack surface?

- A) Add video support to improve the system's multi-modal capabilities.
- B) Remove audio and image modalities; retain text and PDF with active content disabled.
- C) Implement stricter rate limits on audio and image submissions to reduce their usage.
- D) Require multi-factor authentication before any non-text file is submitted.

Answer: B **Explanation:** B is correct because removing unused modalities applies the principle of least privilege at the data-type level—if audio and image inputs are not being used, they represent unnecessary attack surface. PDF with active content disabled is appropriate for the document use case. A is wrong because adding video introduces the highest-risk modality with no business justification. C is wrong because rate-limiting unused modalities reduces but does not eliminate the risk—the attack surface remains open. D is wrong because MFA controls access to the system but does not reduce the modality-level attack surface once the user is authenticated.

Q2. Scenario: An AI document analysis system receives a file with .pdf extension and application/pdf MIME type, but magic number validation reveals MZ header bytes (4D 5A). A security analyst is reviewing an AI-powered document analysis system that accepts PDF uploads from external partners. A penetration tester has submitted a file with the extension .pdf and MIME type application/pdf, but the file's actual content begins with the bytes 4D 5A (MZ header). What does this indicate and what is the correct response?

- A) The file is a corrupt PDF that should be re-requested from the partner.
- B) The file is a Windows executable disguised as a PDF; reject it and alert the security team.
- C) The MIME type is incorrect; re-process the file as an executable.
- D) The magic number check has failed due to encoding differences; allow the file and validate at the model layer.

Answer: B **Explanation:** B is correct because the MZ header (4D 5A) is the file signature of Windows Portable Executable (PE) files—executables and DLLs. A file with this signature but a PDF extension and MIME type is a disguised executable, a classic MIME type spoofing attack. The correct response is immediate rejection and security team alerting. A is wrong because the file is not corrupt—it is an

intentionally mislabelled executable. C is wrong because the system should never re-process user-supplied content as an executable. D is wrong because magic number mismatches are security signals, not encoding artefacts; allowing the file would permit a malicious executable into the processing pipeline.

Q3. Scenario: *An insider threat AI analyses employee screenshots. The security team wants to minimise image processing attack surface while retaining the ability to analyse visible text content.* An AI-powered insider threat detection system analyses employee screenshots submitted via a web portal. The security team wants to process the text content visible in the screenshots while minimising the attack surface from image processing. Which approach BEST achieves this?

- A) Accept only PNG and JPEG images, reject all other formats, and process images directly with a vision model.
- B) Extract text from images using OCR, discard the original image, and process only the extracted text.
- C) Require employees to submit text transcripts of their screenshots rather than the images themselves.
- D) Implement adversarial image detection on all uploaded images before passing them to the vision model.

Answer: B Explanation: B is correct because the downgrade strategy—OCR extraction followed by image discard—eliminates the image modality's attack surface entirely while preserving the functionality needed (text content analysis). The vision model and its vulnerabilities are no longer in the processing chain. A is wrong because format restriction reduces but does not eliminate image-based attack vectors; adversarial images and steganography remain risks within allowed formats. C is wrong because requiring manual transcription is operationally unworkable at scale and removes the efficiency benefit of AI-assisted analysis. D is wrong because adversarial detection is an additional layer over image processing, not a replacement for it—the image modality's attack surface remains open.

Q4. Which of the following BEST describes why a format allow-list is preferred over a format deny-list for modality file type controls in an AI system?

- A) Allow-lists are easier to maintain because the list of safe formats changes less frequently than the list of dangerous formats.
- B) Allow-lists ensure that only explicitly validated formats are processed, eliminating unknown-format risks that deny-lists cannot anticipate.
- C) Allow-lists provide better user experience because users know exactly which formats are accepted.
- D) Allow-lists are required by CompTIA SecAI+ certification standards for all AI systems.

Answer: B Explanation: B is correct because deny-lists can only block formats known to be dangerous at the time the list was created; any new, novel, or exotic format that is not on the deny-list will be accepted regardless of its risk. Allow-lists invert this: only formats that have been explicitly validated and approved are accepted; everything else—including unknown formats—is rejected by default. A is wrong because allow-lists may actually require more maintenance in environments where business needs evolve to require new formats; the security advantage is the fail-safe default, not maintenance simplicity. C is wrong because

user experience is a secondary benefit, not the primary security rationale. D is wrong because no such prescriptive requirement exists in this form.

Q5. A security AI system is being designed to accept video uploads for deepfake detection analysis. Which combination of controls BEST addresses the risks specific to video input?

- A) Implement a 100 MB file size limit and accept all common video formats.
- B) Process video in a VM-level isolated sandbox with no network access, enforce strict size and duration limits, accept only MP4/H.264, and scan for embedded malware.
- C) Require video files to be uploaded via encrypted HTTPS to protect them in transit.
- D) Accept video inputs but limit submissions to authenticated users only.

Answer: B **Explanation:** B is correct because video is the highest-risk modality and requires the most comprehensive defence: VM-level isolation (stronger than container-level), network isolation, aggressive size/duration limits to prevent DoS, a narrow format allow-list, and modality-specific malware scanning. A is wrong because a size limit alone and accepting all formats leaves the parser attack surface wide open—exotic codecs are disproportionately likely to contain vulnerabilities. C is wrong because transport encryption protects data in transit but does nothing to address the modality-level risks once the video is received. D is wrong because authentication controls who can submit, not what the submitted content can do to the system.

Q6. What is the PRIMARY security risk of accepting multi-modal inputs compared to single-modality inputs?

- A) Multi-modal inputs are larger in file size and cause higher network bandwidth costs.
- B) Multi-modal inputs require more complex validation that is harder to implement correctly, multiplying the attack surface.
- C) Multi-modal inputs are not supported by modern AI frameworks and require custom implementation.
- D) Multi-modal inputs violate the principle of data minimisation under privacy regulations.

Answer: B **Explanation:** B is correct because each modality introduces its own unique attack vectors, and combining modalities creates coordinated multi-modal attack possibilities (e.g. an adversarial image combined with a malicious text prompt that together trigger model confusion). The validation complexity grows with each added modality, and errors in any modality's validation logic expose the entire system. A is wrong because bandwidth cost is a resource concern, not a security risk in itself. C is wrong because modern AI frameworks (GPT-4o, Gemini, Claude) natively support multi-modal inputs. D is wrong because data minimisation relates to personal data handling, not to AI input format security.

Q7. An AI security platform processes audio recordings of employee phone calls for compliance monitoring. A security engineer recommends implementing a 60-second audio file duration limit. Which threat does this control MOST directly mitigate?

- A) Subliminal ultrasonic commands embedded in audio files.
- B) Denial-of-service attacks using large audio files to exhaust processing resources.

- C) Steganographic payloads concealed within audio file metadata.
- D) MIME type spoofing of audio files submitted as other document types.

Answer: B **Explanation:** B is correct because audio processing is computationally expensive, and duration directly correlates with processing cost. A 60-second limit prevents attackers from submitting multi-hour recordings that would exhaust CPU/GPU resources—a classic resource exhaustion DoS vector. A is wrong because subliminal commands can be embedded in short audio clips; duration limits do not prevent this attack. C is wrong because steganography in metadata is not related to file duration. D is wrong because MIME type spoofing is addressed by magic number validation, not duration limits.

Q8. Which of the following scenarios represents a steganography attack on an AI system and what is the appropriate mitigation?

- A) An attacker submits a very large image file that exhausts the image processing server's memory; mitigation: file size limit.
- B) An attacker embeds command-and-control instructions in the pixel data of an image that appears normal to human reviewers; mitigation: format conversion to strip embedded data.
- C) An attacker submits an image with the file extension .jpg but with ELF binary headers; mitigation: magic number validation.
- D) An attacker submits a manipulated image that causes the AI vision model to misclassify its contents; mitigation: adversarial detection.

Answer: B **Explanation:** B is correct because steganography is specifically the concealment of data within a carrier file in a way that is invisible to casual inspection. Embedding instructions in pixel LSBs (least significant bits) is the classic technique. Format conversion (decompress and re-compress as a fresh image) destroys the steganographic payload without affecting legitimate image content. A describes a resource exhaustion DoS attack, not steganography. C describes MIME type spoofing—the file is not a legitimate image at all, not an image with hidden data. D describes an adversarial example attack, which is a different category of image-based AI attack.

Q9. A developer is configuring modality sandboxes for an AI platform that processes text, images, and documents. The developer proposes using identical container configurations for all three modalities to simplify operations. What is the MAIN security concern with this approach?

- A) Identical configurations prevent the platform from accepting multiple modalities simultaneously.
- B) A compromise in the higher-risk image or document processing sandbox could propagate to the text processing sandbox if they share the same isolation boundary.
- C) Container-level isolation is insufficient for text processing, which requires VM-level isolation.
- D) Identical sandbox configurations violate the principle of defence in depth.

Answer: B **Explanation:** B is correct because modalities with different risk profiles require different isolation strengths. If image processing (higher risk, higher resource usage) shares the same container configuration as text processing (lower risk, lower resource usage), a successful exploit in the image sandbox has a larger blast radius than it would in a properly isolated, higher-containment sandbox. The contamination risk between modalities is the core concern. A is wrong because sandbox configuration does

not affect which modalities can be accepted simultaneously—these are separate processing pipelines. C is wrong because text processing is the lowest-risk modality and container-level isolation is generally sufficient. D is wrong because defence in depth refers to layered controls, not to differentiated sandbox configurations specifically.

Q10. An organisation's AI threat hunting platform currently accepts only text queries. The security team proposes adding image support so analysts can upload screenshots of suspicious activity for AI-assisted analysis. Which response from the security architect is MOST appropriate?

- A) Approve the request immediately—image support is a standard feature of modern AI platforms.
- B) Reject the request—image inputs are never acceptable in security AI systems.
- C) Approve the request contingent on implementing format allow-listing, magic number validation, malware scanning, sandbox isolation, size limits, and an OCR downgrade option for text-only analysis.
- D) Approve the request and implement a deny-list of known-dangerous image formats before going live.

Answer: C **Explanation:** C is correct because there is a legitimate business case for image support (analysts need to share screenshots), and the request should not be rejected outright. However, adding a new modality requires a full set of compensating controls: format allow-listing, magic number validation, malware scanning, sandbox isolation, size limits, and where possible an OCR downgrade that processes only the extracted text. A is wrong because approving without controls ignores the modality's attack surface. B is wrong because the blanket rejection ignores a legitimate operational need that can be accommodated securely. D is wrong because a deny-list is less secure than an allow-list for file format controls.